CVE-2017-0199 Vulnerability Report

1. Overview & NVD Details

CVE-2017-0199 is a critical Remote Code Execution (RCE) vulnerability in Microsoft Office and Microsoft WordPad. The flaw exists in the way Microsoft Office handles Object Linking and Embedding (OLE) links to malicious embedded objects, specifically HTML Application (HTA) scripts. When a user opens a specially crafted document, the application downloads and executes malicious code.

CVSS v3.0 Severity Score: 7.8 (HIGH SEVERITY)

CVSS V2.0 Severity Score: 9.3 (HIGH)

Attack Vector: Local

Attack Complexity: Low

Privileges Required: None

User Interaction: Required

2. Patch Information

Microsoft issued patches for this vulnerability in the April 2017 Security Update (Patch Tuesday). The updates modify how Windows and Microsoft Office parse embedded OLE objects during document rendering.

Software	Knowledge Base (KB) / Status
Office 2007 SP3	KB3141529
Microsoft Office 2010 SP2	KB3141538
Microsoft Office 2013 SP1	KB3178710
Microsoft Office 2016	KB3178703
Windows WordPad / OS	KB4015549 / Monthly Rollup

3. Cyber Kill Chain Analysis

Reconnaissance: Attackers identify targets in target sectors and acquire email addresses.

Weaponization: A document is crafted with an embedded OLE link pointing to a remote malicious HTA file.

Delivery: Sent via targeted spear-phishing emails with deceptive document names.

Exploitation: Upon opening the document, MS Word contacts the remote URL to fetch the HTA file, which mshta.exe executes.

Installation: The script drops secondary payloads (e.g., trojans, RATs) and creates persistence.

Command and Control: Payload establishes outbound connections to attacker C2 servers.

Actions on Objectives: Data theft, credential harvesting, or further lateral movement.

4. Expert Response and Mitigation

Cybersecurity experts noted that traditional macro blocking was ineffective because CVE-2017-0199 abused standard OLE link resolving rather than VBA macros. Key mitigations include:

- Apply Microsoft Security Updates (KB3178703, KB3178685, KB3178710) immediately.
- Configure Endpoint Detection & Response (EDR) or ASR rules to block Office applications from spawning child processes like mshta.exe or cmd.exe.
- Block outbound network connections initiated by WINWORD.EXE or mshta.exe to untrusted external locations.

5. References

- National Vulnerability Database (NVD) - CVE-2017-0199 Detail: https://nvd.nist.gov/vuln/detail/CVE-2017-0199
- Microsoft Security Update Guide - CVE-2017-0199: https://msrc.microsoft.com/update-guide/vulnerability/CVE-2017-0199
- CISA Known Exploited Vulnerabilities Catalog - CVE-2017-0199: https://www.cisa.gov/known-exploited-vulnerabilities-catalog

- FireEye Threat Research - Zero-Day Vulnerability (CVE-2017-0199) Exploited in the Wild: https://www.mandiant.com/resources/blog/zero-day-vulnerability-cve-2017-0199-exploited-in-the-wild
- Trend Micro Research - CVE-2017-0199 In-Depth Analysis: https://www.trendmicro.com/vinfo/us/threat-encyclopedia/vulnerability/5319/cve-2017-0199
- MITRE ATT&CK Technique - Exploitation for Client Execution (T1203): https://attack.mitre.org/techniques/T1203/